

Path 1: Pre Security > Module 1: Introduction to Cyber Security > Room 2: Defensive Security Intro

<https://tryhackme.com/room/defensivesecurityintro>

Defensive Security Intro:

Introducing defensive security, what it involves and looks like within the real-world, as well as the technologies involved.

>> Task 1: Introduction to Defensive Security?

Q1) What is defensive security also known as?

Answer: Blue Teaming

Unfortunately, headlines show us what happens when defensive security falls short. From large-scale ransomware attacks on healthcare systems to data leaks at major corporations, the impact of poor security can be severe and incredibly costly for an organisation, with fines to follow. Here are some real-world examples:

British Airways (2018)

Personal details such as birth names, addresses, and payment card details of 400,000+ customers were leaked.

British Airways was fined £20 million for this incident.

Marriott International (2020)

The passport information, payment card details, and names of 334 million customers were leaked, partly due to outdated systems.

Marriott International settled a \$52 million lawsuit.

Advanced Computer Software Group (2022)

Medical records and phone numbers for 79,904 people were leaked due to weak security policies.

Government officials fined the organisation £3.07 million.

23andMe (2023)

Over 7 million users' sensitive data, such as names, addresses, health records, and DNA data, was leaked due to poor security policies.

23andMe was fined £2.31 million by government officials.

SK Telecom (2024)

Poorly configured servers led to the personal data of approximately 27 million users being leaked.

SK Telecom were fined \$97 million by government officials.

>> Task 2: Responsibilities of Defensive Security

Some key areas of defensive security:

Monitoring and Detecting
Incident Response
Threat Intelligence
Vulnerability Management
Investigation and Analysis



A defensive security team is made up of a mixture of roles and responsibilities. Below, let's meet some of the highly-skilled individuals you would find within a defensive security team:

SOC Analyst
Incident Responder
Security Engineer
Digital Forensics

Q1) An attack has been detected on an organisation's network. What is the name of the person above who would be responsible for responding to the attack?

Answer: Aaliyah (Incident Responder)

>> Task 3: Defensive Security in Practice

Organisations don't rely on a single tool or method to stay secure — they build layers of defence, much like an onion or many layers to a castle. We call this "Defence in Depth," meaning that if one security measure fails, we have others to rely upon at various stages.

Examples of these defensive measures include:

- Employee Training
- Intrusion Detection Systems (IDS)
- Firewalls
- Security Policies



Security Operations Centre (SOC): This busy centre is the frontline of protecting an organisation, often operating around the clock, 365 days a year, and employs a variety of security professionals who monitor and protect the organisation's networks, systems, and data.

A typical day in the SOC could look like:

- Reviewing alerts triggered by security tooling
- Investigating anomalies
- Responding to incidents

SIEMs: The Defensive Security Radar

Much like a control centre in the real world, SIEMs (Security Information and Event Management) systems are the central place for all data and information collected from security devices, workstations, servers, and more within an organisation.

Q1) What is the abbreviation for the term "Security Operations Centre"?

Answer: SOC

>> Task 4: Practical: Defend FakeBank

Scenario:

You will be joining the defensive security team for FakeBank, a large financial institution. You will be at the forefront of investigating and resolving suspicious events marked as such by FakeBank's sophisticated "**Security Information and Event Management (SIEM)**."

Investigate the "Web Discovery Attack" and perform the necessary, guided, protective measures to stop it from continuing.

- Investigation started
- Implementation Action: Source IP Blocked, Block Duration (24 Hours)
- Implement Rate Limiting for admin endpoints: Time Window (60 seconds), Max Requests per Window (50 Requests)
- Added new Web Application Firewall rules: Block suspicious enumeration attempts (This will create a new WAF rule to block similar attack patterns in the future).

Q1) What is the flag that you obtained by following along?

Answer: THM{FAKEBANK-SECURED}